

The numbers

- 7 pillars, 45 capabilities, 152 activities
- 91 Target (due by the end of FY27); 61 Advanced (after)
- Target bar: every published Target outcome met
- NSA ZIG: Discovery 14, Phase One 36, Phase Two 41 = the 91 Target activities. Phases Three and Four (the 61 Advanced) are not yet published, as of 30 September 2026.
- CISA ZTMM 2.0: 5 pillars + 3 cross-cutting capabilities; 4 stages: Traditional, Initial, Advanced, Optimal

The roadmap in one breath

Seven pillars: User, Device, Application and Workload, Data, Network and Environment, Automation and Orchestration, Visibility and Analytics. Forty-five capabilities, 152 activities. Ninety-one are Target, due by the end of FY27; sixty-one are Advanced. Each activity has published outcomes, and meeting every one is the Target bar. Some programs also report maturity through the CISA model.

Zero Trust question or security question?

A Zero Trust question asks about a per-request access decision made on identity, device posture and context, enforced and logged, or about the inventory, tag or policy that feeds one.

"Is AV installed?" is a security question. "Is device compliance checked before each access decision, with non-compliant access denied by default?" is a Zero Trust question (2.2, 2.7). Rewrite, then note the activity IDs it scores.

Dates

WHEN	WHAT
Aug 2020	NIST SP 800-207
Jul 2022	DoD ZT Reference Architecture v2.0
Oct 2022	DoD ZT Strategy: Target Level by the end of FY27
Apr 2023	CISA ZTMM 2.0
Jun 2024	DoD ZT Overlays (now archived only)
18 Mar 2025	DoD ZT Capabilities and Activities, current
Jan 2026	NSA ZIGs: Primer and Discovery (14 Jan); Phase One and Phase Two (30 Jan)
30 Sep 2027	End of FY27, the Target deadline

Pillars and capabilities (capabilities / Target / Advanced)

PILLAR	C/T/A	CAPABILITIES
1 User	9/13/15	1.1 User Inventory; 1.2 Conditional User Access; 1.3 MFA; 1.4 Privileged Access Management; 1.5 Identity Federation & User Credentialing; 1.6 Behavioral, Contextual ID and Biometrics; 1.7 Least Privileged Access; 1.8 Continuous Authentication; 1.9 Integrated ICAM Platform
2 Device	7/14/10	2.1 Device Inventory; 2.2 Device Detection and Compliance; 2.3 Device Authorization w/ Real Time Inspection; 2.4 Remote Access; 2.5 Automated Asset, Vulnerability and Patch Mgmt; 2.6 UEM & MDM; 2.7 EDR & XDR
3 Application & Workload	5/12/6	3.1 Application Inventory; 3.2 Secure Software Development & Integration; 3.3 Software Risk Management; 3.4 Resource Authorization & Integration; 3.5 Continuous Monitoring and Ongoing Authorizations
4 Data	7/17/14	4.1 Data Catalog Risk Alignment; 4.2 Enterprise Data Governance; 4.3 Data Labeling and Tagging; 4.4 Data Monitoring and Sensing; 4.5 Data Encryption & Rights Management; 4.6 DLP; 4.7 Data Access Control
5 Network & Environment	4/10/3	5.1 Data Flow Mapping; 5.2 Software Defined Networking; 5.3 Macro Segmentation; 5.4 Micro Segmentation
6 Automation & Orchestration	7/13/7	6.1 PDP & Policy Orchestration; 6.2 Critical Process Automation; 6.3 Machine Learning; 6.4 Artificial Intelligence; 6.5 SOAR; 6.6 API Standardization; 6.7 SOC & Incident Response
7 Visibility & Analytics	6/12/6	7.1 Log All Traffic; 7.2 SIEM; 7.3 Common Security and Risk Analytics; 7.4 UEBA; 7.5 Threat Intelligence Integration; 7.6 Automated Dynamic Policies

3.5, 6.4 and 7.6 are Advanced only, so the 91 Target activities span 42 of the 45 capabilities.

Example scoring method (illustrative, not official)

0 not started; 1 initiated; 2 partial (first outcome evidenced); 3 majority; 4 every published outcome met (the Target bar); 5 sustained and measured.

Score to CISA stage: 0 to 1 Traditional, 2 Initial, 3 to 4 Advanced, 5 Optimal. Pillar stage of record = the minimum across its capabilities; the mean = the trend.

Terms

TERM	MEANING
PE / PA / PEP	Policy engine decides, administrator issues, enforcement point allows or blocks each request. PDP = PE + PA.
PIP	Policy information points: identity, device posture, threat intelligence, data tags.
IdP / ICAM	Identity provider; Identity, Credential and Access Management program.
C2C	Comply to Connect: identify, posture-check and authorize a device before network access; quarantine non-compliant.
SDN, macro / micro seg	Programmable segmentation; macro between enclaves, micro per workload on identity.
DLP / DRM	Data loss prevention and rights management; enforcement points that consume data tags.
SIEM / SOAR / UEBA	Log correlation and alerting; automated response; user and entity behavior baselines.
ZIG phases	NSA sequencing of Target activities: Discovery (inventories, analyses), Phase One (foundational controls), Phase Two (build-out).

DoD to CISA map

DoD PILLAR	CISA ZTMM 2.0
1 User	Identity
2 Device	Devices
3 Application & Workload	Applications & Workloads
4 Data	Data
5 Network & Environment	Networks
6 Automation & Orchestration	Automation & Orchestration (cross-cutting)
7 Visibility & Analytics	Visibility & Analytics (cross-cutting)
Governance-heavy capabilities (1.7, 2.2, 3.5, 4.1, 4.2, 6.1), my read	Governance (cross-cutting), in addition to their pillar

Sources

NIST SP 800-207 (csrc.nist.gov). DoD ZT Strategy, Reference Architecture v2.0, and Capabilities and Activities (dowcio.war.gov, Library). NSA ZT Implementation Guidelines and pillar guides (nsa.gov). CISA ZTMM 2.0 (cisa.gov). Full links: kensden.github.io/zero-trust-field-guide/#sources

Naming: Department of War (DoW), authorized by EO 14347, in prose; "DoD" in document titles. CC BY-NC-SA 4.0. Built with Claude.